THREAT INTELLIGENCE ADVISORY ? Struts Exfil campaign
==========

Distribution: TLP:AMBER Analyst handoff Confidence: HIGH (IOCs are defanged)
Affected host: struts-prod-01 Suspected origin IP: 198.51.100.167

1. EXECUTIVE SUMMARY
An external actor executed a multi-stage post-compromise sequence. Endpoint alerting covered only part of it; several persistence and anti-forensic actions were silent. Map every on-disk finding to the ATT&CK techniques below and flag which are NOT in the SAS alert feed.

2. ATT&CK TECHNIQUE MAPPING (MITRE ATT&CK Enterprise)
  T1190 Exploit Public-Facing Application [initial-access] step 1: Struts2 OGNL RCE (CVE-2023-50164)
  T1505.003 Web Shell [persistence] step 2: JSP webshell planted
  T1059.004 Unix Shell [execution] step 3: shell execution
  T1560.001 Archive via Utility [collection] step 4: stage archive for exfil
  T1048 Exfiltration Over Alternative Protocol [exfiltration] step 5: exfiltrate over HTTPS
  T1098.004 SSH Authorized Keys [persistence] step 6: authorized_keys backdoor
  T1053.003 Cron [execution] step 7: cron persistence
  T1070.002 Clear Linux or Mac System Logs [defense-evasion] step 8: selective auth-log wipe

3. RELEVANT VULNERABILITIES (source: NVD, US-Gov public domain)
  CVE-2023-50164 CVSS 9.8 (CRITICAL) v3.1 CWE=CWE-552
    An attacker can manipulate file upload params to enable paths traversal and under some circumstances this can lead to uploading a malicious file which can be used to perform Remote Code Execution. Users are recommended to upgrade to version
    ref: http://packetstormsecurity.com/files/176157/Struts-S2-066-File-Upload-Remote-Code-Execution.html

4. INDICATORS OF COMPROMISE (defanged)
  ip 198.51.100.167
  c2 update-struts[.]example[.]cn
  pool stratum+tcp[:]//xmr[.]struts[.]evil[:]3333
  wallet 4A00000000000000000e40b218944d0

Attribution: MITRE ATT&CK(R) (C) The MITRE Corporation, CC BY 4.0. CVE/CVSS from the U.S. National Vulnerability Database (public domain).